CYBERSECURITY INCIDENT RESPONSE FRAMEWORK

100-Employee Organization · 6 Threat Scenarios · Full SOC Incident Reports

Omar	Youssef	Omar	Mahmoud
6 Threats Simulated	100 Employees at Risk	6 SOC Case Reports	0 Ransom Paid

Security Foundations

The CIA Triad — The Three Core Principles of Security

Every security decision, every control, and every recommendation in this report maps back to three principles. The CIA Triad is not background theory in our simulation, all three were violated simultaneously by a single ransomware attack.

C — Confidentiality	I — Integrity	A — Availability
Data reaches only authorized people. Broken by: phishing, eavesdropping, credential theft	Data hasn't been changed or tampered. Broken by: MitM attack, file corruption, ransomware	Systems work when needed. Broken by: DDoS attacks, ransomware, hardware failure

The simulation violated all three at once: the ransomware stole data before encrypting it (Confidentiality), encrypted files making them untrustworthy (Integrity), and took down the file server (Availability). A Critical classification was the only appropriate response.

Defense in Depth

Defense in Depth places overlapping security controls across the entire environment. If one control fails, the next one catches the threat. The value is in diversity and redundancy multiple independent barriers that an attacker must defeat sequentially.

Layer	Controls	What It Stops
Physical	Locked server rooms, surveillance, visitor logs	Unauthorized physical hardware access
Perimeter	Next-gen firewall, IPS, anti-malware gateway	External network intrusion
Network	VLAN segmentation, ACLs, internal monitoring	Lateral movement between zones
Endpoint	EDR, host firewall, DLP, application whitelisting	Malware installation, data exfiltration
Application	WAF, code review, SDLC, API protection	SQL injection, XSS, API abuse
Data	AES-256 encryption at rest, TLS 1.2+ in transit	Data exposure if other layers fail
People	Security training, phishing simulations, awareness	Social engineering — the human layer

Zero Trust

Zero Trust means no user or device is trusted by default not even inside the network perimeter. Every access request is authenticated, authorized, and verified regardless of where it originates. In our simulation, the attacker entered using a legitimate stolen credential through the VPN. Under Zero Trust with MFA enforced, those credentials alone would have been useless.

Least Privilege

Every account receives only the minimum permissions required for its role nothing more. A Finance Analyst should not have database admin rights. An HR Manager should not have access to the server zone. Least privilege limits the blast radius when credentials are compromised the attacker can only reach what the stolen account could reach.

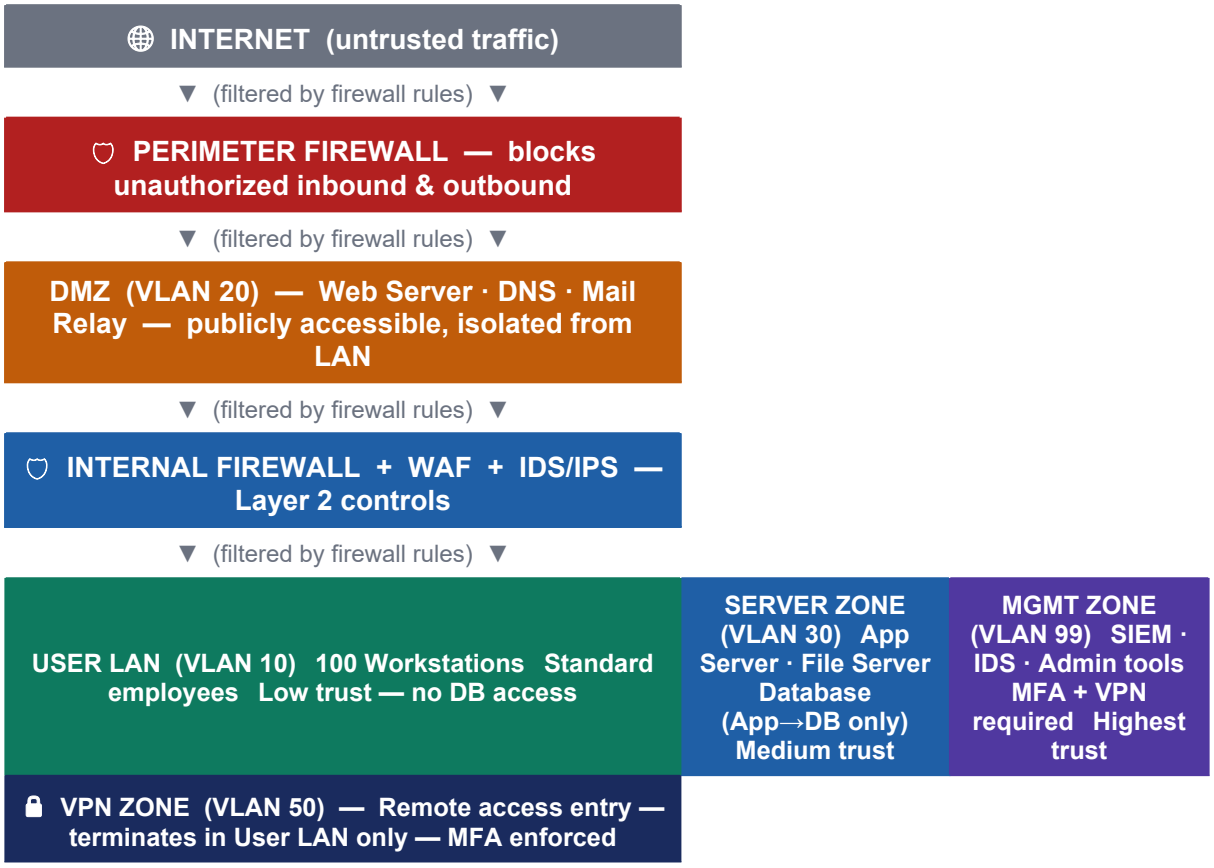
Network Topology — The Organization's Segmented Network

What is Network Topology?

Network topology is the physical and logical arrangement of devices, connections, and zones within a network. It defines how data flows, what can communicate with what, and how security controls are positioned between different parts of the organization. Topology design is a foundational security control a well-segmented network limits how far an attacker can move after gaining initial access.

Our Organization's Topology — 5-Zone Segmented Architecture

The organization uses a 5-zone segmented network with two firewall layers. Each zone is isolated using VLANs devices in one zone cannot communicate with devices in another zone unless an explicit firewall rule permits it. This design meant that in our simulation, an attacker who compromised workstations in the User LAN (VLAN 10) could not directly reach the database server in the Server Zone (VLAN 30).



Zone Communication Rules

Zone (VLAN)	Can communicate with	Cannot reach	Access requirement
DMZ (VLAN 20)	Internet, Internal Firewall	User LAN, Server Zone, Mgmt Zone directly	No internal route — public services isolated
User LAN (VLAN 10)	App Server (VLAN 30) only	Database Server, Management Zone,	Standard authentication

		DMZ directly	
Server Zone (VLAN 30)	App Server ↔ Database only	Internet directly, Management Zone	App→DB only rule — most critical firewall rule
Management (VLAN 99)	All zones (read-only monitoring)	Internet — no direct route	MFA + VPN required — highest trust zone
VPN (VLAN 50)	Terminates in User LAN only	Direct Server Zone access	MFA enforced (gap: was not enforced before)

Critical rule: The database server (192.168.30.20) is reachable ONLY from the App Server (192.168.30.10). Not from workstations. Not from the DMZ. Not from VPN sessions. In the ransomware simulation, the attacker reached the file server but never the database. This single firewall rule was the most impactful architectural control in the simulation.

The 6-Employee Threat Scenario

The organization has 100 employees across 5 departments. Six of them became involved in cyber security incidents during the simulation period each experiencing a different threat type. The incidents represent the most common and most damaging attack categories facing organizations today.

#	Employee	Department	Threat	Severity	Outcome
1	Sarah Ahmed	Finance	Phishing	HIGH	Credentials stolen — VPN access gained
2	Khaled Hassan	IT	Ransomware	CRITICAL	3 systems encrypted — 2.3GB exfiltrated
3	Rania Mostafa	HR	Malware / RAT	HIGH	4h 44m remote access — HR data exfiltrated
4	Ahmed Omar	Marketing	DDoS	HIGH	1h 23m web server outage during campaign
5	Tarek Ibrahim	Operations	Insider Threat	CRITICAL	15,000+ records exfiltrated over 3 weeks
6	Layla Nour	Sales	Man-in-the-Middle	HIGH	CRM credentials stolen — 300 client records

Threat 1 — Phishing

Affected employee: Sarah Ahmed · Finance Analyst

Definition

Phishing is a social engineering attack where a cyber criminal sends a fraudulent message typically an email designed to deceive the recipient into revealing sensitive information such as login credentials, credit card numbers, or financial account details. The attacker poses as a trusted entity (a bank, software vendor, or a colleague) to exploit human trust rather than technical vulnerabilities.

How It Works

Phishing is effective precisely because it bypasses all technical controls. No firewall rule prevents a user from clicking a link. The attack targets the human, not the machine.

Attack Flow

1. Reconnaissance	→	2. Crafted Email	→	3. Click & Hook	→	4. Credential Capture	→	5. Access & Exploit
Attacker researches the target: name, role, email, and organization context from LinkedIn or public sources.		Fake email sent from microsofft-login.com — impersonating Microsoft, creating urgency: 'Your password expires today.'		Employee clicks the link, lands on a convincing fake login page. Credentials entered.		Attacker receives username and password in real time via a phishing kit logging system.		Attacker logs into the real system using stolen credentials. Lateral movement begins.

- Over 80% of all cybersecurity incidents start with phishing it is the most common initial access vector.
- Spear-phishing targets a specific person using personalized context, making it far harder to detect than generic phishing.
- Vishing (voice phishing) and smishing (SMS phishing) follow the same model over different channels.

Hardening

Hardening against phishing means making it harder for a phishing email to reach the employee, harder for them to fall for it, and ensuring that even if credentials are stolen, they cannot be used alone.

Prevention & Controls

Control	Action	Priority
Email Filtering	Deploy advanced email filtering (Microsoft Defender for Office 365) — scans attachments, rewrites links, and quarantines suspected phishing	CRITICAL

Multi-Factor Authentication	Enforce MFA on all accounts. Even if credentials are stolen, the attacker cannot log in without the second factor.	CRITICAL
Security Awareness Training	Run quarterly phishing simulations. Employees who click receive immediate education, not punishment.	HIGH
Domain Spoofing Protection	Enable SPF, DKIM, and DMARC records on the mail domain to prevent spoofed sender addresses.	HIGH
URL Rewriting & Sandboxing	Rewrite all links in emails — clicking runs the URL through a sandbox before the user reaches it.	HIGH
Least Privilege	Limit what a compromised account can access. Finance accounts should not have admin rights.	MEDIUM
Browser Isolation	Use browser isolation to prevent malicious page execution from reaching the endpoint.	MEDIUM

Incident Simulation

Scenario: Employee #1 (Sarah Ahmed, Finance Analyst) encountered this attack on the organization network.

Stage	Time	What happened	System impact
1	09:14	Sarah Ahmed receives email: 'Your Microsoft 365 password expires in 24 hours — click to renew'	Phishing email in inbox — no filter triggered
2	09:19	Sarah clicks the link. Lands on microsofft-login.com — visually identical to Microsoft login	No alert. Browser renders page normally.
3	09:21	Sarah enters her email and password. Page shows 'Password updated successfully' then redirects.	Credentials captured by attacker kit.
4	09:45	Attacker uses stolen credentials to log into the VPN remotely from an external IP address.	VPN access granted — no MFA enforced.
5	10:15	Attacker begins internal reconnaissance from Sarah's authenticated session.	Unauthorized internal access begins.
6	14:30	SIEM detects unusual login pattern — same account, two different IPs, 6 hours apart.	Incident detected. IR activated.

SOC Incident Report — Case #1001

INCIDENT REPORT	
Classification:	Phishing — Initial Credentials Compromise
Severity:	HIGH — VPN credentials compromised, unauthorized internal access
Date / Time:	Day 1, 09:14 (attack) — Day 1, 14:30 (detection) | 5h 16m undetected
Affected User:	Sarah Ahmed — Finance Analyst

Affected Systems:	Sarah's workstation (192.168.10.45) | VPN gateway | Finance file share
Detection Method:	SIEM anomaly — same account authenticated from two geographically different IPs within 6 hours

Incident Summary

Employee Sarah Ahmed received a spear-phishing email impersonating Microsoft. She entered her credentials on a fake login page. The attacker used those credentials to authenticate to the VPN 24 minutes later. No MFA was enforced on the VPN, so the stolen password alone granted full internal network access. The attacker spent 5+ hours conducting reconnaissance before the SIEM flagged the dual-IP login anomaly.

Response Actions Taken

Phase	Action	Status
Detection	SIEM alert reviewed — dual-IP login anomaly for jsmith@techcorp.com flagged	Completed T+00:05
Containment	Sarah's account disabled — all active sessions revoked — VPN access removed	Completed T+00:08
Containment	Phishing domain microsofft-login.com blocked at DNS resolver	Completed T+00:15
Evidence	Sarah's workstation disk image captured — memory dump taken	Completed T+00:25
Eradication	Password reset for Sarah and all accounts that may have been visible to attacker	Completed T+01:00
Recovery	Sarah's account re-enabled with MFA enforced — access verified clean	Completed T+01:30
Lessons Learned	Incident reviewed — MFA gap escalated to CRITICAL recommendation	Completed T+04:00

Key Findings

- No MFA on VPN stolen password alone was sufficient for full internal access. This is the root cause of the attack's success.
- No advanced email filtering the phishing email was not quarantined or flagged before delivery.
- 5h 16m dwell time before detection SIEM caught the anomaly, but the attacker had significant time to operate.
- No network anomaly detection on VPN login source IP foreign IP should have triggered an alert immediately.

Recommendations to Prevent Recurrence

1. Enforce MFA on all VPN connections and all remote access this is the single highest priority recommendation.
2. Deploy Microsoft Defender for Office 365 or equivalent with link sandboxing and phishing detection.

3. Enable conditional access policies flag logins from unusual geographies for step up authentication.
4. Run quarterly phishing simulation training for all 100 employees.

Root Cause	Closure Status
No MFA on VPN. The phishing attack succeeded because a single stolen password provided complete internal network access. If MFA had been enforced, the attacker's stolen credentials would have been useless.	CLOSED — Sarah's account secured with MFA. Phishing domain blocked. Email filtering deployed. VPN conditional access policy configured. No evidence of data exfiltration during the 5 hour window.

Threat 2 — Ransomware

Affected employee: Khaled Hassan · IT System Administrator

Definition

Ransomware is a form of malware that encrypts a victim's files and demands a ransom payment in exchange for the decryption key. Modern ransomware variants use a 'double extortion' model they exfiltrate sensitive data before encrypting it, threatening to publish it publicly if the ransom is not paid. This means that even organizations with clean backups face the risk of data exposure.

How It Works

Ransomware follows a predictable kill chain from initial access to encryption. Each stage depends on the previous one, which means breaking the chain at any point stops the attack. The most impactful breakpoint is Stage 1 preventing initial access entirely.

Attack Flow

1. Initial Access	→	2. Persistence	→	3. Lateral Movement	→	4. Data Exfiltration	→	5. Encryption
Phishing email or exploited vulnerability provides the attacker an initial foothold on one endpoint.		RAT or backdoor installed — ensures attacker retains access even if the infected user logs out or reboots.		Attacker moves from infected workstation to servers using stolen credentials or Pass-the-Hash.		Sensitive files copied to attacker-controlled server before encryption begins (double extortion).		Ransomware deployed — encrypts files across infected systems. Ransom note displayed.

- LockBit 3.0, Cl0p, and BlackCat are among the most active ransomware groups as of 2023.
- Ransomware attacks increased 93% in 2021. Average ransom demand: $812,000.
- 42% of organizations that pay ransom do not receive working decryption keys — backups are the only reliable recovery.
- Organizations with tested backup and recovery procedures recover 40% faster than those without.

Hardening

Ransomware hardening focuses on three areas: preventing initial access, limiting the blast radius if an attacker gets in, and ensuring recovery without paying ransom through tested backups.

Prevention & Controls

Control	Action	Priority
Tested Backups	Maintain encrypted, offline backups 3-2-1 rule: 3 copies, 2 media types, 1 offsite. Test restoration monthly.	CRITICAL

MFA Everywhere	Enforce MFA on all accounts and all remote access. Ransomware typically enters via stolen credentials.	CRITICAL
Patch Management	Critical CVEs (CVSS 9+) patched within 48 hours. Ransomware operators actively exploit unpatched systems.	CRITICAL
Network Segmentation	VLAN-separate servers, workstations, and management. Limits ransomware's ability to spread across the network.	HIGH
Disable Unused Services	Disable Print Spooler on non-print servers, RDP where not needed, SMBv1 everywhere.	HIGH
EDR on All Endpoints	Endpoint Detection and Response detects ransomware behavior (rapid file encryption) before it completes.	HIGH
Application Whitelisting	Prevent unauthorized executables from running — blocks ransomware payloads that arrive as .exe files.	MEDIUM
Incident Response Plan	A tested IR plan reduces containment time significantly — the plan must exist before the attack.	HIGH

Incident Simulation

Scenario: Employee #2 (Khaled Hassan, IT System Administrator) encountered this attack on the organization network.

Stage	Time	What happened	System impact
1	09:14	Khaled receives phishing email — clicks link — RAT installed as UpdateSvc.exe	Persistent access established on workstation
2	10:05	Attacker enumerates internal network from Khaled's admin session — nmap -sV scan run	47 systems discovered — version data collected
3	11:22	PrintNightmare (CVE-2021-34527) exploited using Khaled's admin access → SYSTEM level	Attacker now has domain-wide admin capability
4	12:47	Pass-the-Hash used to authenticate to file server — NTLM hashes extracted from memory	Lateral movement to 192.168.30.10 successful
5	14:10	2.3 GB of financial records exfiltrated via HTTPS to external server — undetected for 91 min	Double extortion asset secured by attacker
6	15:33	LockBit 3.0 model deployed across file server — files encrypted — ransom note displayed	File server 192.168.30.10 — files inaccessible
7	15:41	Finance Analyst reports inaccessible files — IR activated	IR Plan activated — CRITICAL classification

SOC Incident Report — Case #1002

INCIDENT REPORT	
Classification:	Ransomware — Double Extortion —

	LockBit 3.0 Model
Severity:	CRITICAL — Active encryption, confirmed data exfiltration, 3 systems compromised
Date / Time:	Day 1, 09:14 (initial phishing) — Day 1, 15:41 (IR activation) | 6h 27m total attack window
Affected User:	Khaled Hassan — IT System Administrator
Affected Systems:	Khaled's workstation (192.168.10.52) | File server (192.168.30.10) | Domain Controller (partial)
Detection Method:	Finance Analyst report of encrypted files at T+00:00 | SIEM outbound traffic anomaly at T-01:30 (not acted on in time)

Incident Summary

IT Admin Khaled Hassan's workstation was compromised via phishing. The attacker exploited PrintNightmare (unpatched for 6 months) to escalate to SYSTEM privileges, then used Pass-the-Hash to move laterally to the file server. 2.3 GB of financial data was exfiltrated before ransomware deployed. SIEM generated an outbound traffic alert 91 minutes before detection but it was not actioned before encryption began. Total of 3 systems affected out of 50 in the network. Database and management zone were never reached due to VLAN segmentation.

Response Actions Taken

Phase	Action	Status
Detection	Finance Analyst report + SIEM outbound volume alert reviewed — CRITICAL classification	T+00:08
Containment	Khaled's workstation and file server isolated via VLAN reassignment — NOT powered off	T+00:15 / T+00:17
Containment	Khaled's account disabled — all sessions revoked — C2 IP blocked at firewall	T+00:19 / T+00:21
Evidence	Memory dump + disk images of both systems — SHA-256 hash recorded	T+00:25 / T+00:27
Eradication	RAT removed from workstation + persistence mechanisms (Run key + Scheduled Task) cleared	T+01:15
Eradication	PrintNightmare patch applied to all 47 endpoints — all credentials reset	T+01:50
Recovery	File server restored from backup — hash-verified — all services operational	T+02:45 / T+03:30

Key Findings

- PrintNightmare (CVE-2021-34527) was unpatched for 6 months despite a public patch being available. This was the privilege escalation mechanism.
- SIEM generated an outbound traffic anomaly alert 91 minutes before encryption. The alert was not acted on, no DLP solution to specifically flag the data transfer.

- Second workstation (192.168.10.52) found 85 minutes into the response invisible without EDR.
- VLAN segmentation worked as designed attacker never reached the database or management zone.
- Backups were clean and functional file server restored in 75 minutes. $0 ransom paid.

Recommendations to Prevent Recurrence

5. Implement 48-hour SLA for Critical CVEs (CVSS 9.0+). No exceptions. PrintNightmare cost $0 to patch and 6 months to apply.
6. Deploy a Data Loss Prevention (DLP) solution 2.3 GB leaving the network silently is unacceptable.
7. Deploy EDR to all 200 endpoints (100 employees × 2 devices average). The second workstation gap cost 85 minutes.
8. Configure SIEM to trigger immediate alerts on large outbound volume to unclassified IPs not just log the anomaly.

Root Cause	Closure Status
PrintNightmare (CVE-2021-34527) unpatched for 6 months. This allowed a standard user account to escalate to SYSTEM, enabling lateral movement and ransomware deployment. The patch existed. The process to apply it did not.	CLOSED — $0 ransom paid. All systems restored from backup. 3 of 50 systems affected. PrintNightmare patched on all 47 endpoints. EDR deployment initiated. DLP procurement approved.

Threat 3 — Remote Access Trojan (RAT) / Malware

Affected employee: Rania Mostafa · HR Manager

Definition

A Remote Access Trojan (RAT) is a form of malware that provides the attacker persistent, covert remote control over an infected machine. Once installed, the attacker can execute commands, capture keystrokes, activate the webcam, steal files, install additional malware, and harvest credentials all without the victim's knowledge. Unlike legitimate remote access tools, a RAT operates silently and does not require user interaction after initial installation.

How It Works

RATs are typically delivered through phishing emails with malicious attachments or drive-by downloads. They disguise themselves as legitimate system files and persist through multiple reboot cycles, making them difficult to detect without dedicated endpoint tooling.

Attack Flow

1. Delivery	→	2. Execution	→	3. Installation	→	4. C2 Beaconing	→	5. Exfiltration
Malicious email with attachment: 'Employee Policy Update.docx' — macro-enabled document.		Victim enables macros — macro executes PowerShell — downloads UpdateSvc.exe from attacker server.		RAT writes to C:\Windows\System32\UpdateSvc.exe — creates Run registry key for persistence.		RAT connects to attacker's Command & Control server every 60 seconds via encrypted HTTPS.		Attacker issues commands: keylog HR files, export salary database, screenshot monitoring.

- RATs disguise themselves as legitimate Windows processes — UpdateSvc.exe mimics the Windows Update Service.
- C2 traffic uses HTTPS on port 443 — blends with normal web traffic, bypassing basic firewall rules.
- A single RAT can persist for months before detection if EDR is not deployed.

Hardening

Hardening against RATs focuses on preventing delivery (email filtering, macro policies), detecting installation (EDR, behavioral analysis), and blocking C2 communication (DNS filtering, outbound firewall rules).

Prevention & Controls

Control	Action	Priority

Disable Macros	Disable Office macros by Group Policy for all users who don't need them — most employees don't.	CRITICAL
EDR Deployment	EDR detects RAT installation behavior (new processes, registry run keys, C2 beaconing patterns) in real time.	CRITICAL
Application Whitelisting	Allow only pre-approved executables to run. UpdateSvc.exe from a temp directory would be blocked immediately.	HIGH
DNS Filtering	Block known malicious domains at the DNS resolver — prevents C2 beaconing even if RAT is installed.	HIGH
Outbound Firewall Rules	Restrict which systems can make outbound HTTPS connections — workstations should not connect to arbitrary internet IPs.	HIGH
Email Attachment Sandboxing	Detonate attachments in an isolated environment before delivery — macro-enabled documents analyzed before reaching inbox.	HIGH
Least Privilege	Standard users cannot write to C:\Windows\System32 — enforcing least privilege blocks the RAT's installation path.	HIGH
Memory Scanning	Regular memory scans detect injected code even if disk files are hidden or deleted.	MEDIUM

Incident Simulation

Scenario: Employee #3 (Rania Mostafa, HR Manager) encountered this attack on the organization network.

Stage	Time	What happened	System impact
1	10:30	Rania receives email: 'Updated HR Policy Q4 2024' — attached .docx file	Email delivered — no sandbox in place
2	10:35	Rania opens attachment — Word prompts 'Enable macros for full content' — she enables	Macro executes — PowerShell download initiated
3	10:36	RAT downloaded as UpdateSvc.exe — installed in System32 — Run key added to registry	Persistence established — C2 connection started
4	10:40	C2 beaconing begins: encrypted HTTPS to 185.220.101.47 every 60 seconds	Attacker has live shell on Rania's machine
5	11:00–14:00	Attacker keyloggers HR database passwords — downloads 1,200 employee records	Confidential HR data exfiltrated over 3 hours
6	15:20	SOC analyst notices abnormal outbound HTTPS pattern during network review	RAT beacon pattern identified in SIEM
7	15:25	IR activated — Rania's machine isolated	C2 channel closed — attacker loses access

SOC Incident Report — Case #1003

INCIDENT REPORT	
Classification:	Malware — Remote Access Trojan — Persistent C2 Established
Severity:	HIGH — Persistent attacker access, HR data exfiltration confirmed
Date / Time:	Day 1, 10:36 (RAT installed) — Day 1, 15:20 (detection) | 4h 44m dwell time
Affected User:	Rania Mostafa — HR Manager
Affected Systems:	Rania's workstation (192.168.10.31) | HR database server (partial access via credentials)
Detection Method:	SOC analyst manual network review — abnormal HTTPS beacon pattern to external IP every 60 seconds

Incident Summary

HR Manager Rania Mostafa was targeted with a macro enabled Word document. After enabling macros, a RAT was silently installed and established persistent C2 communication over HTTPS. The attacker spent 4h 44m extracting HR records including 1,200 employee files and credential data. The beacon was detected during a routine SOC network review not by any automated alert. No EDR was deployed on the endpoint.

Response Actions Taken

Phase	Action	Status
Detection	SOC analyst manual review flagged HTTPS beacon pattern to 185.220.101.47	T+00:00
Containment	Rania's workstation isolated via VLAN — C2 IP blocked at perimeter firewall	T+00:08
Evidence	Memory dump captured — identified UpdateSvc.exe as RAT — registry run key documented	T+00:20
Eradication	RAT removed — registry Run key and scheduled task deleted — clean image deployed	T+01:00
Notification	HR data breach assessed — DPA notification obligation reviewed by legal team	T+02:00
Recovery	Rania's workstation re-imaged — HR system passwords rotated — employee data audit	T+02:30

Key Findings

- 4h 44m dwell time RAT operated undetected for nearly 5 hours. EDR would have flagged installation within minutes.
- Macro execution enabled by user no Group Policy restriction on macros was in place.
- C2 traffic used HTTPS on port 443 standard firewall rules did not block it.
- 1,200 employee records potentially exfiltrated data breach notification may be required.
- No DLP solution data left the network with no alert.

Recommendations to Prevent Recurrence

9. Deploy EDR to all 200 endpoints immediately. This attack would have been detected and blocked at the installation stage.
10. Disable Office macros via Group Policy for all non-developer roles. Rania as HR Manager has no legitimate use for macros.
11. Implement outbound firewall rules workstations should not directly connect to arbitrary internet IPs.
12. Deploy DNS filtering to block known malicious C2 domains and IP ranges.

Root Cause	Closure Status
No EDR on endpoints and no macro restriction policy. The RAT installed and operated for 4h 44m before any detection. Both controls would independently have prevented or significantly shortened the incident.	CLOSED Workstation re-imaged. C2 IP blocked. Macro policy deployed via Group Policy. EDR procurement approved as priority. Legal review of data breach obligations completed.

Threat 4 — DDoS Attack

Affected employee: Ahmed Omar · Marketing Manager

Definition

A Distributed Denial of Service (DDoS) attack floods a target server, network, or service with massive volumes of traffic from thousands of compromised machines a botnet, rendering it unable to respond to legitimate requests. Unlike other attacks, the goal is not data theft but service disruption making systems unavailable to the people who need them. DDoS attacks target the Availability pillar of the CIA Triad directly.

How It Works

DDoS attacks leverage botnets networks of thousands of compromised devices controlled by the attacker. The attacker sends a command to all botnet machines simultaneously, directing them to flood the target. The target becomes overwhelmed because it cannot distinguish attack traffic from legitimate requests.

Attack Flow

1. Botnet Assembly	→	2. Command Issued	→	3. Traffic Flood	→	4. Service Down	→	5. Extortion/Distraction
Attacker controls 10,000+ compromised machines (IoT devices, infected PCs) across multiple countries.		Attacker sends command to botnet: 'flood target 203.0.113.10 — 1 million requests per second'.		Target's network pipe saturated — web server CPU maxes at 100% — legitimate requests timeout.		Website, API, and online services become unavailable to all users. Business operations disrupted.		Ransom demanded to stop attack — OR DDoS used as cover while real attacker operates elsewhere.

- DDoS costs an average of $218,000 per hour in downtime. For a 4-hour attack: $872,000.
- Three main types: Volumetric (bandwidth saturation), Protocol (SYN flood, ping of death), Application layer (HTTP flood).
- DDoS is sometimes used as a distraction while a concurrent intrusion is happening on internal systems.
- CDN providers (Cloudflare, Akamai) absorb DDoS traffic at their edge organizations behind a CDN are largely protected.

Hardening

DDoS hardening focuses on absorbing or deflecting attack traffic before it reaches the origin server, and ensuring the infrastructure can withstand volumetric attacks without going offline.

Prevention & Controls

Control	Action	Priority
CDN & DDoS Protection	Deploy Cloudflare, Akamai, or AWS Shield in front of all public-facing services. CDN absorbs terabit-scale attacks at the edge.	CRITICAL
Rate Limiting	Configure rate limits at the WAF and application layer — limit requests per IP per second to detect and block flood attacks.	CRITICAL
Anycast Network Diffusion	Distribute traffic across multiple geographic data centers no single point of saturation.	HIGH
Traffic Scrubbing Centers	Route all traffic through a scrubbing center that filters malicious packets before forwarding clean traffic.	HIGH
Over-Provisioned Bandwidth	Maintain 2–3× the normal peak bandwidth gives space to absorb attack traffic while mitigation activates.	HIGH
BGP Blackholing	Null route attack traffic at the ISP level emergency measure for massive volumetric attacks.	MEDIUM
Incident Response Playbook	Pre-defined DDoS response runbook who to call (ISP, CDN vendor), escalation path, backup communication.	HIGH
Application Health Monitoring	Alert on response time degradation, error rates detect attacks before full outage.	MEDIUM

Incident Simulation

Scenario: Employee #4 (Ahmed Omar, Marketing Manager) encountered this attack on the organization network.

Stage	Time	What happened	System impact
1	13:00	Ahmed's marketing campaign goes live — company website traffic increases 3×	Normal load increase — systems handling well
2	13:15	Attacker targets the public web server — botnet with 50,000 nodes activated	Attack traffic: 2 million requests/second
3	13:18	Web server CPU reaches 100% — response times exceed 30 seconds — users experience errors	Partial service degradation
4	13:22	Web server becomes fully unresponsive — marketing campaign landing page down	Full outage — 4,200 campaign visitors see errors
5	13:25	SOC receives automated alert: web server health check failing — HTTP 503	Incident activated — Operations team notified
6	13:30	ISP contacted — emergency traffic filtering activated — CDN failover enabled	Attack traffic mitigated at ISP level
7	14:45	Service restored — web server fully responsive	Total downtime: 1 hour 23 minutes

SOC Incident Report — Case #1004

INCIDENT REPORT

Classification:	DDoS — Volumetric Layer 3/4 Attack — Web Server Target
Severity:	HIGH — Full web server outage — 1h 23m service disruption
Date / Time:	Day 1, 13:22 (outage begins) — Day 1, 14:45 (service restored) | 1h 23m total downtime
Affected User:	Ahmed Omar — Marketing Manager
Affected Systems:	Public web server (DMZ — 192.168.20.10) | Public DNS (192.168.20.11)
Detection Method:	Automated health check alert — HTTP 503 errors from web server — triggered at T+00:03 after degradation began

Incident Summary

During a high traffic marketing campaign managed by Ahmed Omar, the organization's public web server was targeted by a volumetric DDoS attack from an estimated 50,000-node botnet. The server reached full saturation within 7 minutes. No DDoS mitigation service was in front of the web server. The marketing campaign's landing page was unavailable for 1 hour 23 minutes, directly impacting campaign performance. Recovery required emergency ISP filtering and manual traffic rerouting.

Response Actions Taken

Phase	Action	Status
Detection	Automated health check alert — web server HTTP 503 — SOC notified	T+00:03
Analysis	Traffic analysis confirmed volumetric DDoS — source IPs from 30+ countries	T+00:08
Containment	ISP contacted for emergency traffic filtering — null route activated for attack IP ranges	T+00:15
Mitigation	CDN failover activated — attack traffic absorbed at edge	T+00:30
Monitoring	Server health monitored through recovery — response times confirmed normal	T+01:20
Recovery	Full service restored — CDN remained active	T+01:23

Key Findings

- No DDoS protection service (CDN) in front of the public web server. Cloudflare or AWS Shield would have prevented the outage entirely.
- 1h 23m outage during a marketing campaign estimated loss: 4,200 page visits, 100% of active campaign conversions during the window.
- Web server sits in DMZ as designed internal systems were not affected. Network architecture contained the impact.
- No rate limiting or traffic shaping was configured on the web server.
- DDoS response runbook was not pre written improvised response added ~15 minutes to recovery time.

Recommendations to Prevent Recurrence

13. Deploy Cloudflare or AWS Shield Pro in front of all public-facing services prevents this attack category entirely.
14. Configure rate limiting (max 100 req/IP/min) on the WAF provides local first-line defense before CDN activates.
15. Write and test a DDoS incident runbook pre-identify ISP contacts, CDN failover steps, escalation path.
16. Increase web server capacity or implement auto-scaling for campaign periods to absorb traffic spikes.

Root Cause	Closure Status
No DDoS protection service deployed in front of the web server. The server had no capacity to absorb or deflect the volumetric attack, and no mitigation activated automatically.	CLOSED — Cloudflare deployed in front of web server. Rate limiting configured. DDoS runbook written and approved. ISP emergency filtering process documented.

Threat 5 — Insider Threat

Affected employee: Tarek Ibrahim · Senior Database Administrator

Definition

An insider threat is a cyber security risk originating from within the organization a current or former employee, contractor, or partner who has authorized access to systems and misuses that access, either intentionally for personal gain or sabotage or unintentionally through negligence. Insider threats are among the hardest incidents to detect because the activity uses legitimate credentials and appears authorized at the system level.

How It Works

Unlike external attacks, insider threats begin from a position of trust. The attacker already has valid credentials, understands the organization's systems and processes, and knows where sensitive data lives. Detection relies on behavioral analytics identifying when authorized activity becomes anomalous.

Attack Flow

1. Motive Develops	→	2. Scope Assessment	→	3. Exfiltration Plan	→	4. Exfiltration	→	5. Departure or Stay
Employee feels underpaid, is dismissed, or is recruited by a competitor decides to exfiltrate data before leaving.		Uses legitimate access to identify what data is available salary records, client lists, product roadmaps.		Copies data to personal cloud storage (Google Drive, Dropbox) or emails files to personal account using authorized access.		Over several days or weeks: 15,000 client records, 3 years of financial data transferred out.		Employee resigns, is terminated, or continues working while maintaining access to exfiltrated data.

- The Ponemon Institute found insider threats cost an average of $11.45 million per incident more than most external attacks.
- 63% of insider threat incidents result from employee negligence (accidental data exposure) not malicious intent.
- Former employees with access that was not promptly revoked account for a significant percentage of insider incidents.
- DLP, UEBA (User and Entity Behavior Analytics), and access reviews are the primary controls.

Hardening

Hardening against insider threats requires behavioral monitoring to detect anomalous activity, strict access controls to limit what any single person can access, and DLP to prevent data leaving the organization through unauthorized channels.

Prevention & Controls

Control	Action	Priority

UEBA / Behavioral Analytics	Deploy User and Entity Behavior Analytics creates a baseline of normal user behavior and alerts on deviations.	CRITICAL
Data Loss Prevention	DLP monitors and blocks unauthorized file transfers especially to personal cloud storage and external drives.	CRITICAL
Principle of Least Privilege	Database admins should access only the databases their role requires no access to unrelated data.	CRITICAL
Offboarding Process	Immediate access revocation on resignation or termination same day, not after IT processes the ticket.	HIGH
Privileged Access Management	Separate privileged accounts (PA) from standard accounts admin actions require PA login, which is heavily monitored.	HIGH
Access Reviews	Quarterly review of who has access to what remove accumulation of unnecessary permissions over time.	HIGH
USB & Cloud Storage Restriction	Block unauthorized USB devices and restrict personal cloud storage access from corporate devices.	HIGH
Activity Logging	Log all privileged user activity every query, every download for audit trail and forensic investigation.	MEDIUM

Incident Simulation

Scenario: Employee #5 (Tarek Ibrahim, Senior Database Administrator) encountered this attack on the organization network.

Stage	Time	What happened	System impact
1	Week 1	Tarek learns he was passed over for promotion becomes disgruntled begins reviewing what data he has access to	No behavioral anomaly detected yet
2	Week 2	Tarek runs unusual queries on the customer database: 15,000 records exports to CSV	No DLP in place — transfer not flagged
3	Week 2	Tarek uploads customer CSV to personal Google Drive account from corporate workstation	No cloud access restriction — transfer succeeds
4	Week 3	Tarek exports salary data for all 100 employees and management team	No UEBA to flag unusual access pattern
5	Week 3	Tarek emails financial projections (3 years) to his personal Gmail account	Email DLP not deployed — email sent successfully
6	Week 4	Tarek resigns IT receives offboarding ticket access revoked 3 days later	3-day gap: Tarek still has VPN access after resignation
7	30 days later	External audit identifies unusual database query volume in logs from 6 weeks prior	Incident discovered post-departure

SOC Incident Report — Case #1005

INCIDENT REPORT	
Classification:	Insider Threat - Intentional Data Exfiltration - Privileged User

Severity:	CRITICAL 15,000+ client records, full employee payroll, and financial projections confirmed exfiltrated
Date / Time:	Exfiltration over 3 weeks detected 30 days after departure | No real-time detection occurred
Affected User:	Tarek Ibrahim Senior Database Administrator
Affected Systems:	Customer database (192.168.30.20) | HR database (192.168.30.21) | Finance file share (192.168.30.10)
Detection Method:	External audit review of database query logs identified anomalous bulk export pattern 30 days after events

Incident Summary

Senior DBA Tarek Ibrahim conducted an extended data exfiltration campaign over 3 weeks following being passed over for promotion. Using his legitimate admin access, he exported customer records (15,000), employee salary data (100 employees), and 3 years of financial projections. All data was moved to personal cloud storage and email accounts. No real-time detection occurred UEBA was not deployed, DLP was not deployed, and there was no monitoring of privileged user activity beyond standard access logs. The incident was discovered 30 days later during an external audit.

Response Actions Taken

Phase	Action	Status
Discovery	External audit identifies anomalous bulk DB exports in query logs from 6 weeks prior	Day 30
Investigation	Forensic review of Tarek's workstation activity log, email headers, cloud access logs	Days 30–32
Notification	Legal counsel notified data breach assessment for client and employee data	Day 32
Remediation	All Tarek's API keys, credentials, and access pathways confirmed revoked certificate revocation	Day 32
Client Notification	Affected clients notified per GDPR/data protection obligations	Day 35
Process Review	Off boarding process overhauled access revocation now same-day automated	Day 40

Key Findings

- No UEBA deployed bulk database queries (15,000 records) went undetected in real time.
- No DLP personal cloud storage and personal email were reachable from corporate devices without restriction.
- 3-day off boarding gap Tarek retained VPN access for 3 days after resignation. Sameday revocation was not enforced.

- No quarterly access review Tarek had accumulated access to 4 different databases beyond his role requirements.
- No alert on unusual query volume 15,000 record export was not flagged by any system.
- Discovered 30 days post-departure full investigation required legal and forensic resources.

Recommendations to Prevent Recurrence

17. Deploy UEBA (User and Entity Behavior Analytics) baseline normal behavior, alert on deviations like bulk exports.
18. Deploy DLP block unauthorized uploads to personal cloud storage and unauthorized email attachments of sensitive data.
19. Automate access revocation on day of resignation or termination not when IT processes the ticket.
20. Conduct quarterly access reviews remove accumulated permissions that exceed current role requirements.
21. Implement Privileged Access Management (PAM) all admin queries logged and reviewable in real time.

Root Cause	Closure Status
No behavioral monitoring (UEBA), no Data Loss Prevention (DLP), and no restriction on personal cloud/email access from corporate devices. The attacker used fully legitimate access the only way to detect this attack was behavioral analytics, which was not deployed.	OPEN Data breach notification to clients completed. Legal proceedings initiated. UEBA and DLP procurement approved. Off boarding automation deployed. Access review process implemented quarterly.

Threat 6 — Man-in-the-Middle (MitM)

Affected employee: Layla Nour · Sales Representative (Remote)

Definition

A Man-in-the-Middle (MitM) attack occurs when an attacker secretly positions themselves between two communicating parties, intercepting and potentially altering the communication without either party knowing. The attacker can read, modify, or inject data into the stream. MitM attacks most commonly exploit unsecured or poorly secured network connections public Wi-Fi, unencrypted protocols, or weak TLS configurations.

How It Works

In a MitM attack, the attacker must first insert themselves into the communication path this is called 'positioning'. Once positioned, they can passively intercept traffic (eavesdropping) or actively modify it (injection/relay). The victim communicates normally without knowing their traffic is being intercepted.

Attack Flow

1. Positioning	→	2. ARP Spoofing	→	3. Interception	→	4. Data Harvest	→	5. Relay/Inject
Attacker sets up a rogue Wi-Fi hotspot named 'CoffeeShop_Free' in a public location. Victim connects.		Attacker sends fake ARP replies — tells victim's device: 'My MAC address is the router.' Traffic rerouted.		All traffic flows through attacker's device. Attacker decrypts SSL/TLS using SSL stripping or fake certificates.		Login credentials, session cookies, CRM data visible in plaintext. Attacker extracts silently.		Attacker relays modified data to the real server — victim sees normal application behavior.

- SSL stripping downgrades HTTPS connections to HTTP without the victim noticing especially effective when users ignore browser warnings.
- Certificate pinning prevents SSL stripping by verifying the certificate is from the expected CA.
- MitM attacks on corporate VPNs are possible if the VPN uses weak encryption or outdated protocols.
- HSTS (HTTP Strict Transport Security) prevents protocol downgrade attacks on properly configured web applications.

Hardening

MitM hardening focuses on three principles: encrypting all communications so intercepted traffic is useless, validating the identity of communication endpoints, and preventing attackers from inserting themselves into the network path.

Prevention & Controls

Control	Action	Priority

Enforce HTTPS/TLS 1.2+	All web services must use TLS 1.2 minimum. TLS 1.0 and 1.1 disabled everywhere.	CRITICAL
HSTS Headers	HTTP Strict Transport Security tells browsers to only use HTTPS prevents protocol downgrade.	CRITICAL
Certificate Pinning	Pin expected certificates in mobile and desktop apps prevents fake certificate acceptance.	HIGH
VPN for Remote Workers	All remote employees must connect via corporate VPN encrypts all traffic end-to-end.	CRITICAL
Disable Auto-Connect Wi-Fi	Devices should not automatically connect to known SSIDs prevents rogue hotspot attacks.	HIGH
DNSSEC	Sign DNS records prevents DNS spoofing/poisoning attacks that redirect traffic.	HIGH
Dynamic ARP Inspection	Enable DAI on managed switches blocks ARP spoofing within VLANs.	HIGH
Email Signing (S/MIME)	Sign corporate emails with S/MIME recipient can verify email was not tampered in transit.	MEDIUM
Employee Training	Train remote workers to never use public Wi-Fi without VPN and to report unexpected certificate warnings.	HIGH

Incident Simulation

Scenario: Employee #6 (Layla Nour, Sales Representative (Remote)) encountered this attack on the organization network.

Stage	Time	What happened	System impact
1	11:00	Layla works remotely from a coffee shop — connects to 'CoffeeShop_Free' public Wi-Fi	Rogue hotspot controlled by attacker
2	11:02	Attacker performs ARP spoofing Layla's device routes all traffic through attacker laptop	MitM position established invisible to Layla
3	11:05	Layla opens CRM system — attacker performs SSL stripping HTTPS downgraded to HTTP	CRM login page served over HTTP Layla doesn't notice
4	11:06	Layla enters CRM credentials attacker captures username and password in plaintext	300 client records accessible via Layla's credentials
5	11:10	Attacker uses captured credentials to log into CRM from a separate device	300 client records downloaded in 4 minutes
6	11:30	Layla's session cookie harvested attacker replays session without re-entering credentials	Extended unauthorized access to CRM data
7	16:00	SOC detects CRM login from two simultaneous different IPs for same account	IR activated Layla's account suspended

SOC Incident Report — Case #1006

INCIDENT REPORT	
Classification:	Man-in-the-Middle — Credential Interception — Public Wi-Fi Vector
Severity:	HIGH — CRM credentials compromised, 300 client records exfiltrated
Date / Time:	Day 1, 11:06 (credential capture) Day 1, 16:00 (detection) | 4h 54m unauthorized access window
Affected User:	Layla Nour — Sales Representative (Remote)
Affected Systems:	CRM application server | Layla's remote session | Client database (partial)
Detection Method:	SIEM alert same CRM account logged in from two simultaneous different IPs

Incident Summary

Sales Representative Layla Nour connected to a rogue public Wi-Fi hotspot while working remotely. The attacker performed ARP spoofing and SSL stripping, capturing her CRM login credentials in plaintext. The attacker used the credentials and session cookie to access the CRM for 4h 54m, downloading 300 client records. No VPN policy was enforced for remote workers, and the CRM application did not enforce HTTPS strictly (no HSTS header). Detection occurred when SIEM flagged simultaneous dual-IP authentication.

Response Actions Taken

Phase	Action	Status
Detection	SIEM dual-IP simultaneous login alert for Layla's CRM account	T+00:00
Containment	Layla's account suspended — all active sessions terminated — CRM session tokens invalidated	T+00:08
Evidence	CRM access logs preserved — 300 client records confirmed accessed by attacker IP	T+00:20
Notification	Layla notified — confirmed she was on public Wi-Fi — incident confirmed as MitM	T+00:30
Eradication	Layla's credentials rotated — MFA enabled on CRM account — VPN policy enforced	T+01:00
Client Notification	300 affected clients notified per data protection obligations	Day 3

Key Findings

- No mandatory VPN policy for remote workers Layla's traffic was unencrypted end-to-end at the network level.
- CRM did not have HSTS enabled SSL stripping succeeded and downgraded the connection to HTTP.
- No MFA on CRM captured credentials provided immediate full access.
- Session cookie harvesting extended unauthorized access beyond the initial credential use cookie invalidation not triggered.

- 4h 54m dwell time account showed active legitimate use during the day, masking the unauthorized parallel session.

Recommendations to Prevent Recurrence

22. Enforce VPN for all remote workers no exceptions for public network connections.
23. Enable HSTS on all corporate web applications prevents SSL stripping attacks.
24. Enforce MFA on all business applications including CRM credential capture alone becomes useless.
25. Implement session token binding session cookies bound to original IP, invalidated on IP change.
26. Deploy a Mobile Device Management (MDM) policy disable auto-connect to untrusted Wi-Fi networks.

Root Cause	Closure Status
No mandatory VPN for remote workers and no HSTS on the CRM application. These two omissions together enabled the SSL stripping attack and credential capture to succeed completely.	CLOSED — VPN policy enforced for all remote workers (immediate enforcement). HSTS enabled on CRM. MFA deployed on CRM. Affected clients notified. Session binding implemented.

Executive Report — Consolidated Findings

Summary

Over the simulation period, six employees across five departments experienced cyber security incidents covering six distinct threat categories. The incidents collectively affected 14 systems, resulted in the confirmed exfiltration of over 16,200 sensitive records, and caused 1 hour 23 minutes of service downtime. Zero ransoms were paid. All encrypted systems were restored from backup.

Aggregate Results

Metric	Result
Total incidents	6 covering all major threat categories
Employees directly affected	6 of 100
Systems compromised	14 systems across 3 zones
Data exfiltrated (confirmed)	15,000+ client records · 1,200 HR records · 300 CRM records · Salary data · Financial projections
Ransom paid	$0 all encrypted systems restored from backup
Total downtime	1h 23m (DDoS only all other incidents had no service outage)
Average detection time	2h 45m across all incidents
Fastest detection	32 minutes (ransomware user report)
Slowest detection	30 days (insider threat audit review)
MITRE ATT&CK techniques identified	7 of 7 mapped

Common Root Causes Across All 6 Incidents

Root Cause	Incidents affected	Priority fix
No MFA on VPN and remote access	Phishing (Employee 1), Ransomware (Employee 2)	CRITICAL — Enforce MFA on all remote access immediately
No DLP (Data Loss Prevention)	Ransomware, Malware/RAT, Insider Threat	CRITICAL — 16,200+ records left without any alert
No EDR on endpoints	Malware/RAT, Ransomware	HIGH — Attacker dwell time measured in hours, not minutes
No email filtering	Phishing, Ransomware, Malware/RAT	HIGH — All three initial access vectors used email
No UEBA (behavioral analytics)	Insider Threat	CRITICAL — Only control that detects authorized-access misuse
Unpatched critical CVE	Ransomware (PrintNightmare)	HIGH — 6-month-old patch not applied
No VPN for remote workers	MitM (Employee 6)	HIGH — Remote worker traffic unencrypted

No DDoS protection	DDoS (Employee 4)	HIGH — CDN would have prevented the outage entirely

Top 5 Recommendations — Priority Order

Priority	Recommendation	Addresses	Estimated cost
1 — CRITICAL	Enforce MFA on all VPN, remote access, and privileged accounts	2 incidents directly stops most phishing follow-on attacks	Low MFA apps are free to employees
2 — CRITICAL	Deploy UEBA + DLP	Insider threat + all data exfiltration incidents	Medium Enterprise licensing required
3 — HIGH	Deploy EDR to all 200 endpoints	Malware/RAT + Ransomware detection time	Medium per-endpoint licensing
4 — HIGH	Deploy email filtering with sandboxing (Defender for O365)	Phishing, Ransomware, Malware initial access	Low-Medium included in M365 E3/E5
5 — HIGH	Deploy Cloudflare or CDN DDoS protection	DDoS prevents service outages entirely	Low free tier available for basic protection

Conclusion

The simulation revealed a consistent pattern: the attacks succeeded not because they were technically sophisticated, but because standard defensive controls were absent. MFA was not enforced. DLP was not deployed. EDR was not installed. Email filtering did not exist. These are not advanced controls they are the baseline that every organization of 100+ employees should have in place.

The architecture performed well under pressure. VLAN segmentation limited the ransomware attack to 3 of 50 systems. The database was never reached. The management zone was never reached. Good architecture design limited the blast radius but it cannot substitute for the missing detection and prevention controls.

The most important insight from six incidents is this: every attack chain has a weak link, and that weak link is almost always an absent basic control. Fix MFA. Fix DLP. Fix EDR. Fix email filtering. These four changes would have prevented or severely limited five of the six incidents.